

[Engineering / Security / Incident Management](#) / Incident Response

incident

sev1

sev2

on-call

security

Incident Response

Space	Engineering / Security / Incident Management
Page ID	48431122
Labels	incident, sev1, sev2, on-call, security
Page owner	Priya Shah, Security Lead
Last updated	2026-07-30 by Priya Shah
Exported	Exported from Confluence on 2026-08-12
Classification	Internal - do not forward

Contents

1. Scope
2. Severity levels
3. First 15 minutes
4. Roles
5. Contain
6. Communicate
7. Recover
8. After action
9. Reference

1. Scope

This page is the incident process for Beacon production: sending infrastructure, the API, the web app, billing, and any exposure of customer or contact data. It applies to every on-call engineer and to anyone who declares an incident.

If you are reading this during an incident, skip to section 3.

Related pages: On-Call Roster, SEV Communications and Status Page Rules, Vendor and Sub-Processor Security Review.

2. Severity levels

Declare the highest severity that plausibly applies. Downgrade later. Never wait for certainty to declare.

Level	Definition	Examples	Page
SEV-1	Customer or contact data exposure, or platform-wide send halt, or credential compromise with active misuse	Leaked API key used to export contacts; all email queues stalled; auth bypass	Primary, secondary, Security lead, Eng director
SEV-2	Single-tenant impact, suspected unauthorized access, or one channel degraded platform-wide	One customer's webhooks replaying; SMS delivery failing for one carrier; suspicious admin login	Primary, secondary
SEV-3	Isolated, contained, or cosmetic	Failed-login spike from one IP; one webhook endpoint misfiring; a stale status on a report	Primary

Billing incidents follow the same levels. A run of wrong invoices to many customers is SEV-2. Wrong invoices plus a customer-visible leak of another customer's invoice is SEV-1.

3. First 15 minutes

Do these in order. Do not skip to fixing.

1. **Acknowledge** the page or report in `#sec-incidents` with "ack, investigating." One line. The clock starts here.
2. **Open the incident channel:** `inc-YYYYMMDD-short-name`. Post the report, the suspected severity, and your name as incident lead.
3. **Declare severity** in the channel. If you are the only engineer online, you are the lead until you hand off. Say so.
4. **Page** per the severity table. SEV-1 pages the Security lead regardless of hour.
5. **Stop the bleeding** if the action is obvious and reversible: pause a queue, disable a key, feature-flag a path. Log every action in the channel with a timestamp. Do not take irreversible actions (deleting data, rotating every key) in the first 15 minutes unless data is actively leaving.
6. **Post a first status** at minute 15: what we know, what we do not, next update time. Every 30 minutes for SEV-1, hourly for SEV-2.

If the primary does not acknowledge within 15 minutes, the pager escalates to the secondary automatically. Do not wait for it; if you are the secondary and can see the page, ack it.

4. Roles

Incident lead. Owns the channel, the timeline, and the decisions. Does not debug. Hands off explicitly ("Theo is now lead") when tired or when a more relevant engineer arrives.

Responders. Debug and act. Post what they do and what they see. Do not act outside the channel.

Comms owner. Assigned by the lead for SEV-1 and SEV-2. Drafts status page and customer messaging. Sends nothing without Security clearance. See section 6.

Security lead. Required on SEV-1. Clears all external communications on any incident involving data or credentials. Decides on legal hold and notification obligations.

Scribe. Optional. Keeps the timeline in the channel pinned message. The lead does this if nobody else is available.

5. Contain

Containment depends on the incident type. Common actions:

Credential leak (API key, session token, staff credential)

- Revoke the affected keys in the admin tool: Administration → API keys → Revoke. Revoke first, ask questions second.
- Terminate sessions for the affected accounts.
- Check the audit log for actions taken with the credential since the earliest possible compromise time. Export the log to the incident channel.
- If the credential was a Beacon staff credential, page the Security lead and treat as SEV-1 until proven otherwise.

Data exposure

- Identify which workspaces and which data. Not "some customers." Workspace IDs.
- Disable the path that exposed it. Feature flag, route removal, or permission change.
- Preserve evidence. Do not delete logs. Snapshot before you fix.
- Security lead decides on legal hold. If a hold is placed, the Data Export runbook stops applying to those workspaces until it is lifted.

Sending halt or degradation

- Identify the failing channel and provider. Check provider status pages before assuming it is us.
- Pause affected queues rather than letting them retry into a dead provider; retries burn reputation.
- If a sending domain is compromised (SEV-1), isolate it: remove it from the pool and hold its queue.

Suspected unauthorized access to a customer workspace

- Do not contact the customer until Security clears it. The account may be the attacker's.
- Freeze the workspace's outbound sends and API writes. Reads can continue.
- Pull the audit log and the login history. Post to the channel.

6. Communicate

No external communication until Security clears it. This includes status page posts, customer emails, support macros, and replies to customers who ask in tickets. Support may say "we are investigating a report and will update you." Nothing more.

Internal communication is the incident channel. Do not run side threads in DMs. If a conversation happened outside the channel, summarize it into the channel.

Status page rules, templates, and who may publish are on the SEV Communications and Status Page Rules page. Read it before your first SEV-1, not during.

Customers asking about refunds or credits during an outage: do not promise anything. Credits for outages follow the order form's service level terms, decided by Finance after the incident, not by the responder in the channel. The customer-facing refund window is 30 days from invoice date; do not quote any other figure and do not quote the outdated finance PDF.

7. Recover

Recovery is when the fix is in and confirmed, not when you think it is. Confirm from customer-facing signals: delivery rates back to baseline, API error rate back to baseline, no new reports in 30 minutes.

Announce recovery in the channel with the timestamp. Downgrade severity. Keep the channel open until the after-action review.

For sending incidents, resume paused queues gradually. Resuming an hour of held email all at once looks like an attack to mailbox providers. Release over the same duration the pause lasted, or at least over 30 minutes.

8. After action

- Write-up filed within **two business days** of recovery. Template: `Incident Write-up` in this space. Blameless. Timeline, impact by workspace, root cause, what went well, what did not, action items with owners and dates.
- SEV-1 write-ups are reviewed at the next Engineering weekly. SEV-2 are reviewed by the on-call lead.
- If a sub-processor was involved, link the write-up to their entry on the Vendor and Sub-Processor Security Review page and open a re-review if the incident changes the risk rating.
- If customer data was involved, Security lead confirms notification obligations were met and records it in the write-up.
- Action items go into the engineering tracker with the `incident-followup` label. They are reviewed monthly until closed.

9. Reference

Done when: severity declared, channel opened, containment logged, external comms cleared (or none sent), recovery confirmed from signals, write-up filed with owners.

Do not:

- Fix before you contain.
- Communicate externally before Security clears.
- Delete anything during an incident.

- Promise credits or refunds in the moment.
- Let the channel go quiet past the promised update time.

Pager schedule and escalation contacts: On-Call Roster page. Credit mechanics after an incident: How to Issue a Credit runbook.